

RF - 1.3: Permitir Recuperação de Senha

Fluxo Principal (Caminho Feliz)

O usuário acessa a tela de login e clica na opção "Esqueci minha senha".

O sistema solicita o e-mail cadastrado na conta do usuário.

O usuário insere o e-mail e clica em "Enviar link de recuperação".

O sistema valida se o e-mail existe na base de dados:

Se existir: O sistema gera um *token* único de segurança com validade temporária e envia um e-mail ao usuário contendo um link para a redefinição.

Se não existir: Por questões de segurança, o sistema exibe uma mensagem genérica informando que, se o e-mail estiver correto, as instruções foram enviadas (para evitar varredura de e-mails válidos por terceiros).

O usuário acessa seu e-mail e clica no link recebido.

O sistema direciona o usuário para uma tela de "Nova Senha".

O usuário insere a nova senha e a confirmação de senha.

O sistema valida se a nova senha atende aos critérios de complexidade.

O sistema atualiza a senha no banco de dados, invalida o *token* utilizado e redireciona o usuário para a tela de login com uma mensagem de sucesso.

Regras de Negócio

Expiração do Token: O link de recuperação enviado por e-mail deve expirar automaticamente após 30 minutos (ou conforme política de segurança da empresa).

Uso Único: O *token* deve ser invalidado imediatamente após o primeiro uso com sucesso.

Complexidade da Senha: A nova senha não pode ser igual às últimas 3 senhas utilizadas (opcional, dependendo do rigor do sistema) e deve conter requisitos mínimos (ex: 8 caracteres, letras, números e símbolos).

Segurança de Mensagem: Em nenhuma etapa o sistema deve confirmar explicitamente se o e-mail não existe na base durante a fase de solicitação, visando evitar engenharia social.

Requisitos de Interface (UI)

Campo de Input: Validação de formato de e-mail em tempo real.

Feedback Visual: Exibição de mensagens de erro (senha não coincide) e sucesso (senha alterada com êxito).

Botão de Ação: Destacado para "Redefinir Senha".

Exceções e Tratamento de Erros

E-mail Inválido: Caso o formato do e-mail seja incorreto, o sistema deve impedir o envio.

Token Expirado: Se o usuário clicar no link após o tempo limite, o sistema deve exibir a mensagem: "Este link expirou. Por favor, solicite uma nova recuperação."

Falha no Envio de E-mail: Caso o serviço de disparo de e-mails falhe, o sistema deve registrar o log de erro e notificar o usuário para tentar novamente mais tarde.